==========
CHECKPOINT 2 – INFRASTRUCTURE ASSESSMENT
==========

Target: 192.168.56.101 Environment: Authorized Metasploitable2 Lab Assessment Type: Infrastructure Security Assessment

========== 1. OBJECTIVE
==========

The objective of this assessment was to assess the infrastructure layer of the authorized lab target 192.168.56.101.

The assessment focused on:

- Network services and exposed ports
- Service and software versions
- Authentication mechanisms
- Anonymous access
- Patch and version weaknesses
- Infrastructure-level vulnerabilities
- Security misconfigurations

Nmap and Nmap NSE scripts were used to identify services, authentication mechanisms, and security weaknesses.

========== 2. METHODOLOGY
==========

The following activities were performed:

1. Network service and port enumeration using Nmap.
2. Operating system detection.
3. Service and version identification.
4. FTP anonymous-access assessment.
5. SSH authentication-method assessment.
6. Telnet service assessment.
7. SMB share and anonymous-access assessment.
8. MySQL authentication assessment.
9. PostgreSQL service assessment.
10. VNC security assessment.
11. HTTP method and header assessment.
12. DNS service assessment.
13. SMTP command enumeration.
14. Apache and SSL/TLS vulnerability assessment.
15. Nmap vulnerability scanning.
16. Evidence was saved as individual text files.

All testing was performed against the authorized lab target 192.168.56.101.

========== 3. TARGET INFORMATION ==========

Target IP: 192.168.56.101

Operating System: Linux 2.6.x

Nmap OS detection identified the target as running a Linux 2.6.x kernel, with OS details in the range Linux 2.6.9 – Linux 2.6.33.

========== 4. EXPOSED NETWORK SERVICES ==========

The following services were identified during the assessment:

Port Service Observation

21 FTP vsftpd 2.3.4 22 SSH Password/Public-key authentication 23 Telnet Telnet service exposed 25 SMTP SMTP commands available 53 DNS BIND 9.4.2 80 HTTP Apache 2.2.8 / PHP 5.2.4 111 RPC rpcbind 139 SMB Samba / NetBIOS 445 SMB Microsoft-DS 512 rexec Remote execution service 513 rlogin Remote login service 514 rsh Remote shell service 1099 Java RMI RMI registry 1524 Ingreslock Exposed service 2049 NFS Network File System 2121 FTP Alternative FTP service 3306 MySQL MySQL 5.0.51a 5432 PostgreSQL PostgreSQL service 5900 VNC VNC protocol 3.3 6000 X11 X11 service 6667 IRC IRC service 8009 AJP13 Apache JServ Protocol 8180 HTTP Apache Tomcat service

The large number of exposed services increases the attack surface of the system.

========== 5. AUTHENTICATION ASSESSMENT ==========

5.1 FTP

The FTP service on port 21 allowed anonymous FTP login.

Evidence: Nmap ftp-anon script reported:

“Anonymous FTP login allowed (FTP code 230)”

This indicates that authentication was not required for anonymous FTP access.

5.2 SSH

SSH was available on port 22.

The SSH authentication assessment identified:

- publickey authentication
- password authentication

Password-based authentication increases the importance of using strong passwords and appropriate access controls.

5.3 SMB

SMB services were available on ports 139 and 445.

The SMB share enumeration identified anonymous access to certain shares.

The “tmp” share allowed:

- Anonymous READ access
- Anonymous WRITE access

IPC$ also showed anonymous access.

This represents an important access-control weakness.

5.4 MySQL

MySQL was available on port 3306.

The Nmap mysql-empty-password script reported:

“root account has empty password”

This indicates that the MySQL root account did not have a password configured in the assessed lab environment.

========== 6. PATCH AND VERSION ASSESSMENT ==========

Several legacy software versions were identified.

Important examples include:

- Apache 2.2.8
- PHP 5.2.4
- BIND 9.4.2
- MySQL 5.0.51a
- Linux 2.6.x
- vsftpd 2.3.4
- Samba 3.0.20-Debian

These versions are significantly outdated and indicate that the system requires software and security patch updates.

Version information alone was not treated as proof of every possible CVE. Confirmed findings were based on the evidence obtained from the Nmap NSE scripts.

========== 7. CONFIRMED SECURITY FINDINGS ==========

FINDING V-01

Title: Anonymous FTP Access

Target: 192.168.56.101

Port: 21/tcp

Service: FTP / vsftpd 2.3.4

Evidence: Nmap ftp-anon reported that anonymous FTP login was allowed with FTP response code 230.

Impact: Unauthorized users may be able to access files exposed through the FTP service.

Severity: Medium

CVSS: 5.3 (Analyst-assigned)

FINDING V-02

Title: Anonymous SMB Read/Write Access

Target: 192.168.56.101

Ports: 139/tcp and 445/tcp

Evidence: SMB share enumeration identified the “tmp” share with anonymous READ/WRITE access.

Impact: An unauthenticated user may be able to read or modify files available through the exposed share.

Severity: Medium

CVSS: 6.5 (Analyst-assigned)

FINDING V-03

Title: MySQL Root Account With Empty Password

Target: 192.168.56.101

Port: 3306/tcp

Evidence: Nmap mysql-empty-password reported that the root account has an empty password.

Impact: Unauthorized access to the database may be possible if the database is reachable and the root account is permitted to connect.

Severity: Critical

CVSS: 9.8 (Analyst-assigned for the demonstrated lab configuration)

FINDING V-04

Title: Java RMI Remote Class Loading Exposure

Target: 192.168.56.101

Port: 1099/tcp

Evidence: Nmap rmi-vuln-classloader reported:

“RMI registry default configuration allows loading classes from remote URLs which can lead to remote code execution.”

The NSE script reported the state as VULNERABLE.

Impact: A vulnerable RMI configuration may allow remote code loading and potentially remote code execution.

Severity: Critical

CVSS: 9.8 (Analyst-assigned)

FINDING V-05

Title: SSL/TLS CCS Injection

Evidence: The Nmap vulnerability scan reported:

ssl-ccs-injection: State: VULNERABLE

Description: SSL/TLS MITM vulnerability (CCS Injection)

CVE: CVE-2014-0224

Severity: High

CVSS v3.1: 7.4

FINDING V-06

Title: SSLv3 POODLE

Evidence: The Nmap vulnerability scan reported:

ssl-poodle: State: VULNERABLE

The scan identified SSL 3.0 support.

CVE: CVE-2014-3566

Severity: Low

CVSS v3.1: 3.4

FINDING V-07

Title: Weak Diffie-Hellman Parameters

Evidence: The Nmap vulnerability scan reported:

ssl-dh-params: State: VULNERABLE

The scan identified a weak Diffie-Hellman group with a 1024-bit modulus.

Impact: Weak cryptographic parameters may reduce the security of encrypted communications.

Severity: Configuration weakness

CVSS: Not assigned because the exact impact depends on the affected service and communication context.

========== 8. RISK SUMMARY ==========

The assessment identified several security weaknesses.

Highest-priority findings:

1. MySQL root account with an empty password.
2. Java RMI remote class-loading exposure.
3. SSL/TLS CCS Injection.
4. Anonymous SMB read/write access.
5. Anonymous FTP access.
6. SSLv3 POODLE exposure.
7. Weak Diffie-Hellman parameters.

The target also exposes a large number of legacy network services, increasing the overall attack surface.

========== 9. RECOMMENDATIONS ==========

1. Disable anonymous FTP access unless it is specifically required.

2. Configure strong authentication for FTP.

3. Remove anonymous READ/WRITE permissions from SMB shares.

4. Disable unnecessary SMB shares and services.
5. Set a strong password for the MySQL root account.
6. Restrict database services so they are accessible only from trusted hosts.
7. Disable unsafe Java RMI remote class loading.
8. Upgrade outdated operating system and application components.
9. Disable SSLv3.
10. Upgrade vulnerable SSL/TLS libraries.
11. Replace weak Diffie-Hellman parameters with stronger cryptographic parameters.
12. Disable unnecessary legacy services such as Telnet, rlogin, rexec and rsh.
13. Restrict externally accessible services using firewall rules and network segmentation.
14. Regularly perform vulnerability and patch assessments.

10. EVIDENCE COLLECTED

The following evidence files were collected during the assessment:

- checkpoint2_http80.txt
- checkpoint2_ftp_anonymous.txt
- finding_01_anonymous_ftp.txt
- checkpoint2_ssh_auth.txt
- checkpoint2_telnet.txt
- checkpoint2_smb_shares.txt
- checkpoint2_mysql_empty_password.txt
- checkpoint2_postgresql.txt
- checkpoint2_vnc.txt
- checkpoint2_http_methods.txt
- checkpoint2_dns.txt
- checkpoint2_smtp.txt
- checkpoint2_http_headers_curl.txt
- checkpoint2_apache_vuln.txt
- checkpoint2_os_detection.txt
- checkpoint2_nmap_services.txt
- checkpoint2_vuln_scan.txt

11. CONCLUSION

The infrastructure assessment of the authorized Metasploitable2 lab target 192.168.56.101 identified multiple exposed network services, weak authentication configurations, outdated software, and confirmed infrastructure-level vulnerabilities.

The most significant issues were the empty MySQL root password, anonymous SMB read/write access, anonymous FTP access, Java RMI remote class-loading exposure, and SSL/TLS vulnerabilities.

The assessment demonstrates the importance of reducing the attack surface, enforcing strong authentication, removing unnecessary services, and keeping operating systems and software updated.

==========
END OF REPORT
==========